RAPPORT TECHNIQUE

Projet Supercar

Site web de vente de voitures de luxe

Champ	Valeur
Candidat	RAZAFIMAHEFA Lorryc Irinah Fahendrena
N° candidat	02542605412
Épreuve	E6 — Conception et développement d'applications (SLAM)
Session	BTS SIO 2026
Établissement	MCCI Business School
Période de réalisation	10/11/2024 – 20/09/2025
URL de production	https://lorryc.alwaysdata.net
Dépôt GitHub	https://github.com/Lorryc02

1. Présentation du Projet

1.1 Contexte et objectifs

Supercar est un site web responsive de vente de voitures neuves et reconditionnées, conçu dans le cadre du BTS Services Informatiques aux Organisations (option SLAM). Il a été développé seul sur la période du 10 novembre 2024 au 20 septembre 2025 au sein de la MCCI Business School.

L'objectif principal est de proposer :

- Une vitrine élégante et moderne pour les véhicules haut de gamme (Porsche, BMW, Mercedes, etc.)
- Un système de réservation d'essai en ligne sécurisé
- Un back-office administrateur complet pour la gestion du catalogue et des demandes

1.2 Architecture du système

Le projet repose sur une architecture web dynamique à deux modules :

Module	Description	Accès
Front-office (Interface client)	Catalogue de voitures, filtres de recherche, réservation d'essai, catalogue de services	lorryc.alwaysdata.net/index.php
Back-office (Interface admin)	Gestion des voitures, services, demandes d'essai — CRUD complet sécurisé	lorryc.alwaysdata.net/dashboard.php

2. Technologies et Environnement Technique

2.1 Stack technique

Couche	Technologies
Front-end	HTML5, CSS3, JavaScript, Bootstrap 5
Back-end	PHP (architecture MVC)
Base de données	MySQL / MariaDB (hébergé AlwaysData)
Hébergement	AlwaysData — lorryc.alwaysdata.net
Versionnement	GitHub — github.com/Lorryc02
Maquettage	Canva Pro
IDE	Visual Studio Code
Tests API	Postman
Administration BDD	phpMyAdmin

2.2 Architecture MVC

Le projet suit le patron de conception Modèle–Vue–Contrôleur (MVC) :

- Modèle : gestion des entités en base de données (voitures, utilisateurs, demandes d'essai, services, réservations)
- Vue : pages HTML/CSS avec Bootstrap 5, responsive sur mobile, tablette et ordinateur
- Contrôleur : scripts PHP gérant les interactions entre la base de données et les vues

2.3 Structure de la base de données

La base de données relationnelle MySQL/MariaDB est organisée autour des tables principales suivantes :

Table	Rôle principal	Relations
voitures	Catalogue des véhicules (marque, modèle, prix, stats)	Référencée par demandes_essai
users	Comptes utilisateurs et administrateurs	Référencée par demandes_essai, reservations_services
demandes_essai	Demandes de réservation d'essai routier	FK → users, FK → voitures
services	Catalogue des services proposés	Référencée par reservations_services

Table	Rôle principal	Relations
reservations_services	Réservations de services atelier	FK → users, FK → services

3. Front-office — Interface Client

3.1 Design et responsive design

L'ensemble du design a d'abord été prototypé sur Canva Pro, puis intégré avec Bootstrap 5 pour garantir la compatibilité sur tous les appareils. Le site est 100% responsive grâce au système de grille Bootstrap et à un menu hamburger (dropdown) qui s'adapte automatiquement aux écrans mobiles et tablettes.

Appareils pris en charge :

- Smartphone — menu hamburger, mise en page colonne unique
- Tablette — navigation condensée, grille 2 colonnes
- Ordinateur — navigation complète, grille 3 colonnes

3.2 Fonctionnalités principales

Catalogue de voitures avec filtrage avancé

Le catalogue présente l'ensemble des véhicules disponibles avec leurs photos haute qualité, descriptions, prix et caractéristiques techniques (puissance, vitesse max, accélération, nitro). Un système de filtrage à 3 niveaux permet de rechercher par :

- Marque (BMW, Porsche, Mercedes, etc.)
- Prix (tranches définies)
- Type de voiture (SUV, Coupé, Sport, Cabriolet, Électrique, Compact)

Réservation d'essai

Lorsqu'un client clique sur « Réserver un essai » depuis la fiche d'un véhicule, il est redirigé vers le formulaire de demande d'essai avec pré-remplissage automatique des champs : marque, modèle et type. Le client complète ensuite la date, l'heure, le lieu et un commentaire optionnel. Un message de confirmation s'affiche après soumission.

Catalogue de services

Le site propose un catalogue de services (Essai de voiture, Entretien véhicule, Polissage carrosserie, etc.). Le client connecté peut réserver un service en choisissant une date et un créneau horaire. Une confirmation s'affiche à la validation.

4. Back-office — Interface Administrateur

4.1 Authentification sécurisée

L'accès à l'interface d'administration est protégé par un système de connexion par identifiant et mot de passe. Les pages admin sont protégées par une vérification de session PHP avec redirection automatique vers la page de connexion pour tout accès non autorisé. Le rôle de l'utilisateur est vérifié à chaque requête.

- Vérification du rôle (admin / client) à chaque accès
- Gestion de sessions PHP sécurisées
- Redirection automatique si session expirée ou rôle insuffisant
- Message d'erreur en cas d'identifiants invalides

4.2 Tableau de bord

Le tableau de bord affiche les statistiques clés du site en temps réel, permettant à l'administrateur d'avoir une vue globale sans modifier le code.

Statistique	Source
Nombre d'utilisateurs inscrits	Table users
Nombre de voitures disponibles	Table voitures
Demandes d'essai en attente	Table demandes_essai
Réservations de services	Table reservations_services

4.3 CRUD — Gestion du catalogue

L'interface admin permet la gestion complète (Créer, Lire, Modifier, Supprimer) des entités du site, sans modification directe du code ou de la base de données.

Entité	Créer	Modifier	Supprimer	Consulter
Voitures	✓	✓	✓	✓
Services	✓	✓	✓	✓
Demandes d'essai	—	✓ (statut)	✓	✓
Réservations services	—	✓ (statut)	—	✓
Utilisateurs	—	✓ (rôle)	—	✓

4.4 Règle métier — Limitation de l'augmentation des prix

Une règle métier a été implémentée pour encadrer les modifications de prix des véhicules par l'administrateur. Deux contraintes sont appliquées simultanément :

- Interdiction de diminuer le prix actuel d'un véhicule
- L'augmentation est plafonnée à +20% du prix actuel (ex : 100 000 € → max 120 000 €)

Cette règle est implémentée à deux niveaux pour une sécurité maximale :

Niveau	Mécanisme	Rôle
Côté client (JS)	Vérification en temps réel à chaque frappe — affichage immédiat de l'alerte et désactivation du bouton	Confort utilisateur (UX)
Côté serveur (PHP)	Récupération du prix actuel en BDD, calcul du plafond avec round(), blocage si dépassement	Sécurité réelle (non contournable)

Extrait du code PHP de vérification :

```
// 1. Récupérer le prix actuel depuis la BDD
$stmt_prix = $conn->prepare('SELECT prix FROM voitures WHERE id = ?');
$prix_actuel = round((float)$result['prix'], 2);

// 2. Calculer le plafond exact (+20%)
$plafond = round($prix_actuel * 1.20, 2);
// Ex: 100000 * 1.20 = 120000.00 (exact, pas 119999.99)

// 3. Bloquer si diminution ou dépassement
if ($nouveau_prix < $prix_actuel) { /* erreur diminution */ }
if ($nouveau_prix > $plafond)    { /* erreur +20% */ }
```

5. Sécurité et Intégrité des Données

5.1 Mécanismes de sécurité applicatifs

Mécanisme	Implémentation
Protection injections SQL	Requêtes préparées (prepare / bind_param) sur toutes les requêtes
Gestion des sessions	session_start() + vérification $_SESSION['role'] sur chaque page protégée
Validation des entrées	Filtrage et nettoyage des données POST avant traitement
Protection XSS	htmlspecialchars() sur toutes les sorties dynamiques
Hashage des mots de passe	Implémenté dans le système d'authentification
Restriction d'accès admin	Redirection automatique vers login.php si rôle insuffisant

5.2 Triggers et procédures stockées MySQL

Afin de garantir la robustesse de la base de données, des mécanismes avancés MySQL ont été implémentés directement au niveau du SGBD. Ces contraintes s'appliquent même en cas d'accès direct à la base, indépendamment du code applicatif.

Trigger — Prévention des doublons de créneaux

Ce trigger BEFORE INSERT empêche qu'un même créneau (date + heure) soit réservé deux fois pour un essai routier. En cas de doublon, MySQL lève une erreur SQL 1644 avec un message explicite.

```
CREATE TRIGGER trg_demandes_essai_before_insert
BEFORE INSERT ON demandes_essai
FOR EACH ROW
BEGIN
  IF EXISTS (
    SELECT 1 FROM demandes_essai
    WHERE date_essai = NEW.date_essai
    AND heure_essai = NEW.heure_essai
  ) THEN
    SIGNAL SQLSTATE '45000'
    SET MESSAGE_TEXT = 'Créneau déjà réservé.';
  END IF;
END;
```

Procédure stockée — Insertion sécurisée d'une demande d'essai

La procédure sp_insert_demande_essai centralise la logique métier d'insertion. Elle vérifie d'abord la disponibilité du créneau avant d'insérer, offrant une protection double avec le trigger.

Procédure stockée — Mise à jour du statut des réservations

La procédure sp_update_reservation_status valide strictement les valeurs autorisées ('en_attente', 'confirmee', 'annulee') avant toute mise à jour. Toute valeur invalide est rejetée avec un message d'erreur.

Mécanisme BDD	Type	Protection assurée
trg_demandes_essai_before_insert	TRIGGER BEFORE INSERT	Doublon de créneaux d'essai impossible
sp_insert_demande_essai	PROCÉDURE STOCKÉE	Insertion sécurisée avec double vérification
sp_update_reservation_status	PROCÉDURE STOCKÉE	Validation stricte des statuts autorisés

6. Tests et Validation

6.1 Tests fonctionnels

Scénario testé	Résultat attendu	Statut
Inscription et connexion client	Session créée, redirection accueil	✓ OK
Connexion admin avec mauvais mot de passe	Message d'erreur, accès refusé	✓ OK
Accès direct à dashboard.php sans session	Redirection vers login.php	✓ OK
Filtrage voitures par marque/prix/type	Affichage des voitures correspondantes uniquement	✓ OK
Réservation d'essai sur créneau libre	Insertion en base, message de succès	✓ OK
Réservation d'essai sur créneau occupé	Erreur SQL 1644 (trigger), message d'erreur	✓ OK
Modification prix +15% (dans la limite)	Mise à jour acceptée	✓ OK
Modification prix +25% (hors limite)	Refus côté JS + côté PHP serveur	✓ OK
Diminution du prix d'un véhicule	Refus immédiat avec message explicite	✓ OK
Mise à jour statut invalide (procédure)	Rejeté par sp_update_reservation_status	✓ OK
Upload image avec format non autorisé	Rejet de l'upload, message d'erreur	✓ OK

6.2 Tests de sécurité

- Tentative d'injection SQL dans les formulaires → bloquée par les requêtes préparées
- Tentative d'accès à l'admin sans session → redirection automatique vers login.php
- Soumission d'un formulaire avec données XSS → neutralisées par htmlspecialchars()
- Contournement JS de la limite prix via requête HTTP directe → bloqué par PHP serveur

7. Compétences Développées

Compétence	Mise en œuvre dans le projet
Concevoir et développer une solution web dynamique	Architecture MVC complète — PHP + MySQL + Bootstrap 5
Mettre en œuvre une interface responsive	Bootstrap 5 Grid, menu hamburger, 3 breakpoints validés
Gérer des contenus multimédias	Carrousel hero, galerie photos voitures, upload sécurisé
Concevoir un back-office administrateur complet	Dashboard, CRUD voitures/services/demandes, statistiques
Gérer les données MySQL	5 tables liées, clés étrangères, triggers, procédures stockées
Développer des interfaces CRUD sécurisées	Requêtes préparées, sessions, validation serveur + client
Mettre en œuvre des mécanismes de sécurité	Anti-injection SQL, anti-XSS, hash mots de passe, sessions
Documenter et structurer le projet	GitHub, phpMyAdmin, scripts SQL, maquettes Canva Pro

8. Conclusion

Le projet Supercar constitue une réalisation complète et professionnelle d'un site web de vente de véhicules de luxe. Il démontre la maîtrise de l'ensemble de la chaîne de développement web : de la conception de la maquette sur Canva Pro jusqu'au déploiement en production sur AlwaysData, en passant par la mise en place d'une base de données sécurisée.

Sur le plan technique, le projet se distingue notamment par l'implémentation de mécanismes avancés de sécurité et d'intégrité des données au niveau du SGBD (triggers, procédures stockées), ainsi que par l'application de règles métier rigoureuses comme le plafonnement des augmentations de prix à 20%. Ces contraintes sont appliquées à la fois côté client (JavaScript) et côté serveur (PHP), garantissant une sécurité maximale contre toute tentative de contournement.

Ce projet illustre concrètement les compétences attendues du BTS SIO option SLAM : conception d'une solution applicative web dynamique, gestion sécurisée des données, développement d'interfaces CRUD, et mise en œuvre de mécanismes de sécurité conformes aux bonnes pratiques du secteur.

Accès	URL / Identifiants
Site client	https://lorryc.alwaysdata.net/index.php
Connexion client	client@gmail.com / password
Interface admin	https://lorryc.alwaysdata.net/dashboard.php
Connexion admin	admin@gmail.com / password
GitHub	https://github.com/Lorryc02